INSTITUT PUIG CASTELLAR

A3.2. Pràctica: Vulnerabilitats i escaneig de xarxa amb Nmap

0226. Seguretat informàtica	GRUP: SMX2_
RA3. Aplica mecanismes de seguretat activa descrivint-ne les característiques i relacionant-les amb les necessitats d'ús del sistema informàtic.	
NOM I COGNOMS: Posa el teu nom i cognoms.	**DATA:** Escriu la data.

Enunciat de l'activitat:

Aquesta activitat es cenyeix a l'apartat NF3-AA2 (Vulnerabilitats) del RA3: amenaces, vulnerabilitats, CVE, risc, i eines de detecció (escàners de xarxa, IDS/IPS). La part pràctica fa servir Nmap, una eina real i legítima quan s'utilitza sobre sistemes propis o amb autorització expressa.

IMPORTANT — ús ètic: Nmap només s'ha d'utilitzar sobre equips propis, de l'aula, o amb autorització explícita per escrit del propietari. Escanejar xarxes alienes sense permís pot constituir un delicte (accés no autoritzat a sistemes informàtics).

Identificació de les captures. Abans de començar qualsevol pas amb el terminal d'Ubuntu, canvia el nom de l'equip pel teu nom i cognom, perquè quedi clar que les captures les has fet tu:

1) Executa sudo hostname nom-cognom, amb el teu nom i primer cognom en minúscules, sense accents ni espais (p. ex. sudo hostname joan-sanchez).

2) Tanca el terminal i obre'n un de nou: l'indicador i la barra superior de la finestra mostraran el nom nou (p. ex. usuario@joan-sanchez).

El canvi és temporal: si la màquina virtual es tanca, es reinicia o s'apaga, es perd, i a la sessió següent cal tornar a executar sudo hostname nom-cognom. Totes les captures de terminal que lliuris han de mostrar aquest nom; les que no el mostrin no es consideraran vàlides.

Enunciat exercici 1

Explica la diferència entre amenaça, vulnerabilitat i risc, amb un exemple propi (inventat) per a cadascun dels tres conceptes, relacionat amb un ordinador de l'aula d'informàtica.

Enunciat exercici 2

Entra a la web cve.mitre.org o a nvd.nist.gov i cerca una CVE publicada en els últims 12 mesos que afecti un programa que coneguis (navegador, sistema operatiu, aplicació...). Indica:

a) el codi CVE-AAAA-NNNNN;

b) la puntuació CVSS i la gravetat;

c) un resum en les teves paraules de en què consisteix la vulnerabilitat.

Enunciat exercici 3

Aplica la fórmula Risc = Probabilitat × Impacte a aquest escenari: un servidor de fitxers amb dades de nòmines es troba en una sala amb pany electrònic, però la contrasenya de l'aplicació de nòmines és "1234" i la coneixen tots els treballadors.

a) Valora l'impacte (baix/mitjà/alt) i justifica-ho.

b) Valora la probabilitat (baix/mitjà/alt) i justifica-ho.

c) Proposa UNA mesura concreta que redueixi el risc sense haver de canviar la ubicació física del servidor.

Enunciat exercici 4

Instal·la Nmap al teu equip (o màquina virtual Linux/Windows) amb `apt install nmap` (Linux) o des de nmap.org (Windows). Executa un escaneig dels 20 ports més habituals sobre el teu propi equip (localhost/127.0.0.1) amb l'ordre: nmap --top-ports 20 -sV -Pn 127.0.0.1



Captura real: escaneig dels 20 ports més habituals fet expressament per a aquesta guia sobre un servidor de proves. Tots els serveis (FTP, SSH, HTTP, RDP, VNC, MySQL...) apareixen com a "closed": és el resultat esperat en un sistema net, sense serveis exposats innecessàriament.

Fes el mateix escaneig sobre EL TEU equip i adjunta la teva pròpia captura [CAPTURA]. Respon:

a) Quants ports apareixen com "open" al teu equip?

b) Si n'hi ha algun, a quin servei correspon i és realment necessari que estigui actiu?

Enunciat exercici 4

c) Per què és una bona pràctica de seguretat minimitzar el nombre de ports oberts ("superfície d'atac")?

Enunciat exercici 5

Executa ara un escaneig de descobriment d'amfitrions ("host discovery") sobre la teva pròpia xarxa local amb l'ordre: nmap -sn 192.168.1.0/24 (adapta el rang a la teva xarxa real, consultant primer la teva pròpia IP amb ipconfig/ifconfig). [CAPTURA]



Captura real de referència (escaneig -sn sobre una xarxa de proves de només 4 adreces): mostra quins amfitrions estan actius sense escanejar-ne els ports.

Respon:

a) Quants dispositius actius has trobat a la teva xarxa?

b) Per què aquesta tècnica és útil per fer un INVENTARI de xarxa (relaciona-ho amb el que ja vau veure al mòdul de Xarxes Locals)?

c) Per què, en un context de pentesting, sovint es prefereix fer aquest descobriment en mode passiu enlloc d'enviar paquets actius?

Enunciat exercici 6

Una petita empresa (una gestoria) et contracta com a tècnic per fer una primera auditoria de seguretat bàsica dels seus 8 ordinadors i el seu servidor. Elabora un pla d'actuació que inclogui:

1) quines eines utilitzaries per detectar vulnerabilitats (escàners, CVE, etc.);

2) com prioritzaries les vulnerabilitats trobades (fórmula de risc);

3) quina eina de detecció d'intrusions (IDS/IPS o honeypot) recomanaries per al servidor, i per què;

4) un breu apartat sobre la importància de revisar els logs periòdicament, encara que no s'hagi detectat cap incident.

Fonts: Repositori "Materials" (GitHub, SMX-0226SI), NF3/AA2-vulnerabilitats.md (CC-BY-SA-4.0); CVE-Mitre (cve.mitre.org); INCIBE-CERT; Nmap (nmap.org).